

XX科技有限公司

IT 安全管理制度

版本号： V2.1

生效日期： 2025年3月1日

编制部： 信息技术部

审批人： 信息安全委员会

密 级： 内部公开

一、总则

为加强XX科技有限公司（以下简称「公司」）的信息技术安全管理，保障公司信息资产的机密性、完整性和可用性，依据《中华人民共和国网络安全法》《中华人民共和国数据安全法》《中华人民共和国个人信息保护法》等相关法律法规，结合公司实际情况，特制定本制度。

本制度适用于公司全体员工，包括但不限于正式员工、试用期员工、实习生、劳务派遣人员、外包服务人员及顾问等所有接入公司信息系统的内外部人员（以下统称「员工」）。本制度由信息技术部（以下简称「IT部」）负责制定、解释、监督执行及定期修订。各部门负责人为本部门信息安全第一责任人，须确保本部门员工知晓并遵守本制度各项规定。

本制度自 2025 年 3 月 1 日起施行，原 V2.0

版同时废止。IT部每年至少对本制度进行一次全面评审，并根据法律法规变化、技术发展及安全态势适时修订。修订内容经信息安全委员会审议通过后发布，全体员工须在发布后 10 个工作日内完成在线学习与确认。

二、账号与密码管理

2.1 账号管理

公司为每位员工分配唯一的系统账号，命名规则为「姓名全拼@domain」格式（如 zhangshan@xxtech.com），账号与员工身份绑定，具有唯一性和可追溯性。账号仅限本人使用，严禁转借、共享或借用他人账号。员工应对其账号下的一切操作行为负责。

账号生命周期管理遵循以下规定：

- 入职开通：新员工入职当日，由IT部根据人力资源部提供的《新员工入职通知单》在 2 个工作小时内完成账号开通及初始密码分发；
- 权限变更：员工岗位调动时，原部门负责人应在调动生效前 3 个工作日提交《权限变更申请表》，IT部据此调整系统权限；
- 离职注销：员工离职（含主动离职、辞退、合同到期不续签）后 2 小时内，IT部须完成其所有系统账号的禁用操作，24 小时内完成账号归档及数据交接；
- 定期审计：IT部每季度对公司所有活跃账号进行一次全面审计，核查账号权限与岗位职责是否匹配，禁用「僵尸账号」（连续 30 天未登录的账号），审计结果形成书面报告报信息安全委员会备案。

2.2 密码策略

所有系统账号密码须满足以下安全强度要求：

- 最小长度：密码长度不少于 12 位；
- 复杂度：须包含大写字母、小写字母、数字、特殊符号四类字符中的至少三类（即禁止纯数字或纯字母密码，如「password123」不符合要求）；
- 有效期：密码最长使用期限为 90 天，到期后系统强制要求修改，新密码不得与前 5 次历史密码重复；
- 锁定策略：连续 5 次输入错误密码，账号自动锁定 30 分钟，锁定期间须联系 IT 服务台（分机

8888) 进行身份核验后解锁；

禁止行为：严禁将密码写在便签纸上粘贴于显示器、键盘、办公桌等可见位置，严禁通过即时通讯工具或电子邮件以明文形式传输密码，严禁在浏览器中保存核心系统密码。

IT部每季度通过弱口令扫描工具对全公司账号进行安全性检测，发现弱口令的账号将被立即锁定，由账号所有人携带员工证至IT部现场重置。对于连续两次被检测出使用弱口令的员工，将通报其部门负责人并纳入当月绩效考核扣分项。

三、数据安全

3.1 数据分类

公司数据根据其敏感程度和泄露后的影响程度，划分为以下三个安全等级：

公开级（Public）：已公开发布或可对外公开的信息，如公司官网内容、对外宣传资料、已发布的新闻稿等。该类数据可在公司内外自由传播，但仍需确保其完整性和来源真实性。

内部级（Internal）：仅限公司内部使用但一旦泄露不会造成重大损失的信息，如内部通知公告、培训材料、一般性工作文档、经脱敏后的统计数据等。该类数据不得发送至公司外部，通过企业微信、公司内网或经批准的内部分享平台流转。

机密级（Confidential）：泄露后可能对公司造成严重经济损失、法律风险或竞争优势损害的信息，包括但不限于：源代码及系统架构文档、客户合同及报价信息、财务报表及审计底稿、核心算法模型及参数、未公开的产品路线图、员工个人隐私数据（含薪酬、绩效、身份信息）。机密级数据必须加密存储（AES-256及以上标准），传输须使用加密通道（TLS

1.2/1.3），访问须经部门负责人及数据所有者双重审批，并保留完整的访问日志（日志保存期不少于 3 年）。

每位员工在创建、存储、传输数据时，须根据上述分类标准对数据打标。对于无法确定分类等级的数据，默认按机密级处理并及时咨询IT部。IT部每半年对各业务部门的数据分类进行抽样审查，对分类不当的数据要求限期整改。

3.2 数据备份

为确保公司数据在发生硬件故障、人为误操作、自然灾害或安全事件后能够及时恢复，IT部执行以下定期备份策略：

- 数据库备份：每日凌晨 2:00 执行全量备份，备份文件经压缩与加密后同步至异地灾备中心；
- 服务器快照：每周日凌晨 3:00 对核心业务服务器执行系统级快照，快照保留遵循 7-4-12 策略（即保留最近 7 份日备份 + 4 份周备份 + 12 份月备份）；
- 备份验证：每月随机抽取 3 份备份文件进行还原测试，验证备份数据的完整性与可用性，测试结果记录在《备份验证日志》中；
- 恢复演练：每季度至少组织一次全流程灾难恢复演练，模拟数据库崩溃、勒索软件加密等场景，检验 RTO（恢复时间目标 ≤ 4 小时）和 RPO（恢复点目标 ≤ 1 小时）是否达标，演练报告报信息安全委员会。

各部门如需对特定数据进行额外备份或恢复操作，须提前填写《数据恢复申请表》，经部门负责人及IT部负责人审批后由IT部运维团队执行。严禁员工私自使用外部存储设备（如个人移动硬盘、U盘、个人云盘等）备份公司数据。

四、网络安全

4.1 VPN使用规范

员工因出差、远程办公等工作需要，从公司外部（如家庭网络、公共网络等）接入公司内部系统时，必须使用公司提供的VPN（虚拟专用网络）客户端进行安全接入。具体要求如下：

- 客户端获取：VPN客户端须从公司内部软件中心（soft.xxtech.com）下载安装，严禁从第三方网站或非官方渠道获取，以防下载到包含恶意代码的仿冒版本；
 - 使用原则：仅在需要访问内部系统时连接VPN，工作完成后应及时断开连接（建议单次连接时长不超过 8 小时），不得长时间保活占用VPN并发资源；
 - 账号安全：VPN账号与员工个人身份绑定，严禁将VPN账号及密码转借他人使用，一经发现按严重违纪处理；
 - 日志审计：所有VPN连接行为均生成审计日志（含连接时间、断开时间、来源IP、访问目标等字段），日志数据保留至少 90 天，IT部每月对异常连接（如非工作时段连接、异常地理位置连接、大流量下载等）进行审查。
- 员工使用公共Wi-Fi（如酒店、咖啡厅、机场等）接入VPN时，应确保先连接VPN再访问公司内部系统，避免敏感数据在未加密的公共网络上传输。如发现VPN连接异常、速度骤降或频繁断开，应立即断开连接并报告IT服务台。

4.2 邮件安全

公司企业邮箱是员工开展日常工作沟通的主要工具，全体员工应遵守以下邮件安全规范：

- 邮件使用：工作邮件收发必须使用公司企业邮箱（@xxtech.com），禁止使用个人邮箱（QQ邮箱、163邮箱、Gmail等）处理工作事务，以确保邮件数据的存档合规与安全管控；
- 外部邮件处理：收到外部发件人（非 @xxtech.com 域）的邮件时，应在点击链接或下载附件前仔细核实发件人身份。对带有「紧急」「付款」「账号变更」等诱导性标题的外部邮件，务必通过电话或当面与发件人二次确认，确认无误后方可操作；
- 钓鱼邮件报告：如收到疑似钓鱼邮件（含假冒登录页面链接、索要密码或敏感信息的邮件等），应立即通过Outlook客户端的「报告钓鱼邮件」按钮进行举报，IT部安全运营团队将在 30 分钟内响应处置。不得自行转发、回复或点击其中的任何链接和附件；
- 钓鱼演练：IT部每月组织一次全员钓鱼邮件模拟演练，发送模拟钓鱼邮件测试员工的识别能力。对未通过测试（即在模拟邮件中点击链接或提交信息）的员工，须在 5 个工作日内完成信息安全再培训课程。连续两次未通过测试的，通报部门负责人并扣减当月绩效考评分 2 分。

五、设备管理

公司为员工统一配发的办公设备（包括但不限于台式计算机、笔记本电脑、移动终端、打印机、扫描仪等）属于公司固定资产，员工仅有使用权，不得私自转借、出租、出售或挪作他用。设备管理的核心规定如下：

安全预装：所有公司配发设备在交付员工前，均由IT部预装经批准的操作系统、防病毒软件、终端管理（MDM）客户端及全盘加密软件（如 BitLocker/FileVault），员工不得自行卸载、禁用或绕过上述安全软件；

● 加密要求：公司笔记本电脑及移动终端必须启用全盘加密，开机密码须与系统登录密码区分，设置 BIOS/UEFI 开机密码以增强物理安全防护；

网络接入：公司配发设备仅允许接入公司内网或公司授权的VPN，个人设备（含手机、平板、个人笔记本等）仅允许连接访客专用 Wi-Fi（SSID: XXTech-Guest），访客网络与公司内网物理隔离，无法访问任何内部系统；

● 设备丢失：如发生设备丢失或被盗，员工须在发现后 30 分钟内报告直属上级及IT部（24小时应急电话：139XXXXXXX），IT部将立即启动远程数据擦除程序，最大限度地防止公司数据泄露。因延迟报告导致数据外泄的，将追究当事人责任；

离职归还：员工离职前须将全部公司配发设备交还IT部，由IT部进行安全检测、数据清除及资产回收登记，确认无误后方可办理离职手续。设备未归还或存在人为损坏的，按设备账面净值从最后薪资中扣除相应赔偿。

IT部每半年对公司配发设备进行一次资产盘点和安全合规检查，核对设备台账与实际持有情况，检查安全软件运行状态及系统补丁更新情况。检查结果报资产管理部门及信息安全委员会。

六、违规处理

违反本制度规定的行为，公司将根据违规行为的性质、情节严重程度及造成的后果，采取分级处理措施。各级处理方式可单独适用，也可合并适用：

● 一级处理（口头警告）：适用于初次轻微的违规行为，且未造成实际安全影响。由直属上级或IT部进行口头提醒，并在员工绩效档案中记录；

● 二级处理（公司通报）：适用于重复违规或较严重的违规行为，由IT部报人力资源部，在全公司范围内发布书面通报批评，取消当年度评优资格；

● 三级处理（经济处罚）：适用于造成一定经济损失或重大安全隐患的违规行为，根据损失程度处以 500 元至 50,000

元不等的罚款（罚款金额由信息安全委员会根据直接经济损失、数据敏感程度、影响范围等因素裁定），同时扣发当月全部绩效工资；

● 四级处理（解除劳动合同）：适用于严重违规行为，包括但不限于：故意泄露机密级数据、蓄意破坏公司信息系统、利用公司网络从事违法犯罪活动、多次（3 次及以上）严重违反信息安全规定且屡教不改等。公司有权依法单方解除劳动合同，不作经济补偿；

● 五级处理（法律追诉）：违规行为涉嫌违法犯罪的（如侵犯商业秘密罪、非法获取计算机信息系统数据罪、破坏计算机信息系统罪等），公司在作出内部处理的同时，依法向公安机关报案，追究当事人的刑事及民事责任。

各部门负责人对本部门员工的信息安全行为承担连带管理责任。本部门在一年内发生 3

起及以上信息安全违规事件，或发生一起造成重大损失的安全事件，部门负责人在当年度绩效考核中直接降档一级（如从 A 档降至 B 档），并取消当年度晋升及评优资格。

公司鼓励员工相互监督，发现信息安全违规行为或安全隐患应主动报告IT部（举报邮箱：security@xxtech.com）。对于提供有效线索的员工，公司将根据贡献程度给予适当奖励（500 元至 10,000 元）。举报人信息严格保密，公司严禁任何形式的打击报复行为。

附 则

本制度未尽事宜，参照国家相关法律法规及公司其他管理制度执行。各部门可根据本制度制定本部门的信息安全实施细则，但不得与本制度的强制性规定相抵触。

本制度的最终解释权归公司信息技术部所有。修订及补充条款自发布之日起生效，与本制度具有同等效力。

XX科技有限公司 信息技术部

2025 年 3 月 1 日